AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Crédit Océane (fictif) · Passerelle de paiements

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:19**

Run: **03-oceane-paiements-limites**

1. Executive summary

OPINION AT TESTING

Needs improvement

7 controls tested	**1** findings	**0** findings closed and verified	**1** open findings
0 human approvals	**20** personal data items masked in evidence	**0 min 18 s** audit duration	**$0.307 *** measured AI cost

Critical: 0 High: 1 Medium: 0 Low: 0

Key messages

- 1 finding across 7 controls: 1 high.
- 1 finding remains open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Crédit Océane (fictif)
System	Passerelle de paiements
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	A. Auditeur
Date	2026-11-02 23:19
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.2	Mandatory MFA for users of critical system	High	Non-compliant		Open	2027-01-31
—	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Compliant			
—	PSI-4.3	Strong password policy	Medium	Compliant			
—	PSI-4.4	Account lockout after failed logins	Medium	Compliant			
—	PSI-4.5	Inactive session timeout	Medium	Compliant			
—	PSI-4.6	Logging of administration actions	High	Compliant			
—	PSI-4.7	No generic or shared admin accounts	High	Compliant			

4. Detailed findings and controls

F-01 **PSI-4.2** Mandatory MFA for users of critical system — High — Non-compliant — Open

CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions
PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`
Expected: `true`
mfa_users is False.

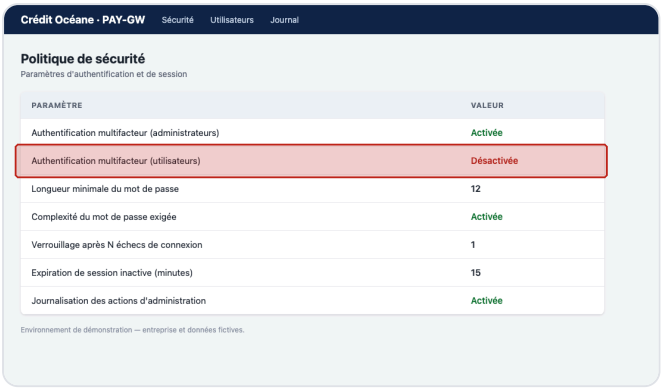
RISK

Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true
Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true

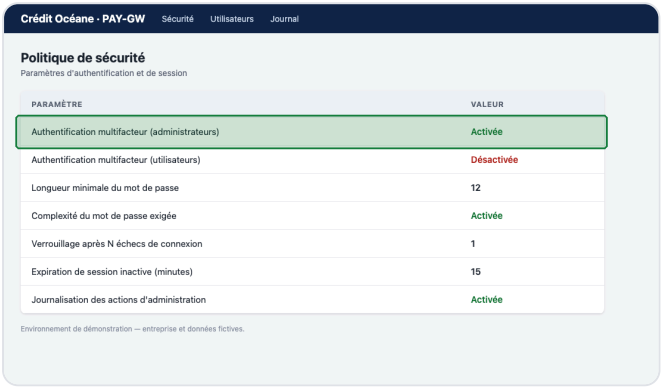


At testing — The screenshot corroborates the test. The table shows user MFA as Désactivée, confirming mfa_users is false.
`2026-11-02 23:19:59 · SHA-256 a034a23afacedc86…`

PSI-4.1 Mandatory MFA for privileged accounts

Critical · Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

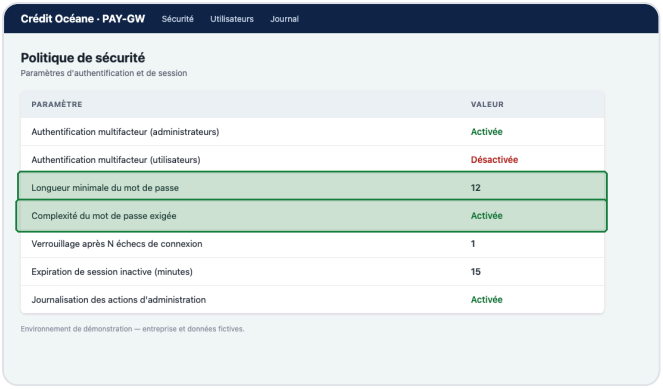


At testing — The screenshot corroborates the test. The security policy table shows administrator MFA as Activée, matching the API result.
`2026-11-02 23:19:58 · SHA-256 e48b7a0c413b0ce9…`

PSI-4.3 Strong password policy

Medium · Compliant

Compliant control — Passwords require a minimum length of 12 characters with complexity requirements enabled · DORA 9(4)(d)
Observed: `{"password_min_length": 12, "password_require_complexity": true}`

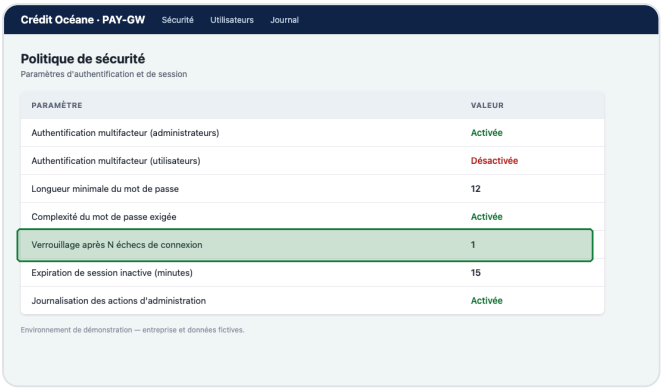


At testing — The screenshot corroborates the test. Screenshot shows minimum password length of 12 and password complexity enabled.
2026-11-02 23:20:00 · SHA-256 6fd71fe0bb65c6d2…

PSI-4.4 Account lockout after failed logins

Medium · Compliant

Compliant control — Accounts lock after at most 5 failed login attempts and lockout is never disabled · DORA 9(4)(c)
Observed: `1`

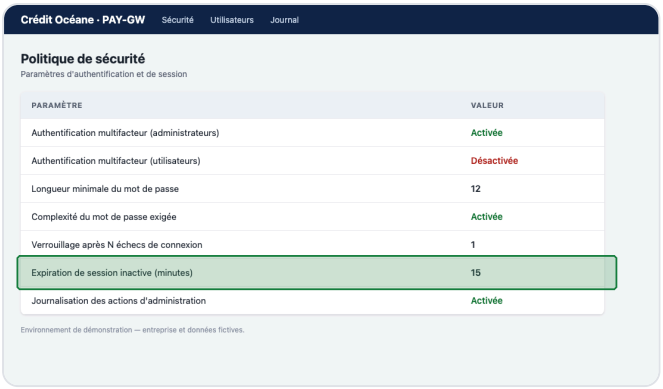


At testing — The screenshot corroborates the test. The screenshot shows lockout after 1 failed login, which is within the required 1 to 5 range.
2026-11-02 23:19:58 · SHA-256 7ebe41eaba3a7434…

PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Inactive sessions expire after at most 15 minutes and expiration is never disabled · DORA 9(4)(c)
Observed: `15`

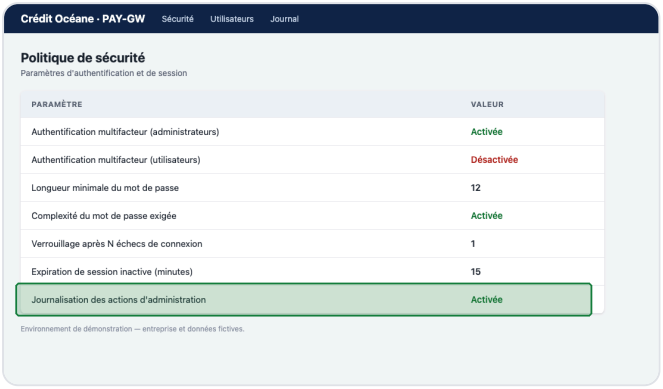


At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 15 minutes, matching the automated test.
`2026-11-02 23:19:57 · SHA-256 8effb2b8bd897b99…`

PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`

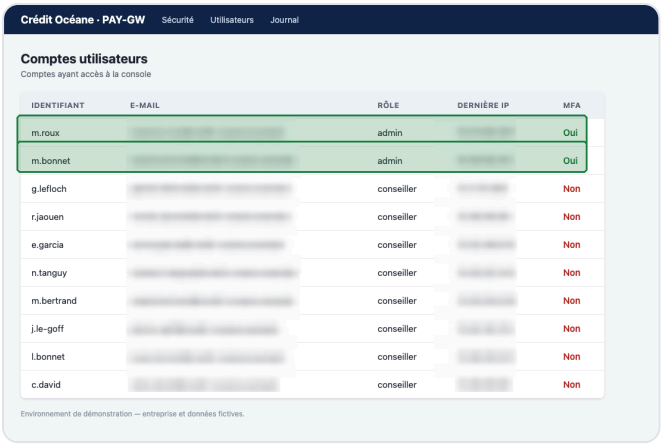


At testing — The screenshot corroborates the test. The screenshot shows admin action logging is set to Activée.
`2026-11-02 23:19:57 · SHA-256 b80a46132bed2850…`

PSI-4.7 No generic or shared admin accounts

High · Compliant

Compliant control — No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)
Observed: `[{"login": "m.roux", "email": "m•••@credit-oceane.example", "role": "admin"}, {"login": "m.bonnet", "email": "m•••@credit-oceane.example", "role": "admin"}]`



At testing — The screenshot corroborates the test. The table shows exactly two admin accounts with initiale.nom logins and personal emails · 20/20 personal data items masked (18 spotted by the AI, the rest by the deterministic safety net)

`2026-11-02 23:20:09 · SHA-256 774c7fd4c38a1288…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Non-compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-02 23:19:58	e48b7a0c413b0ce988d81c29660c67dbefd2b7039dc97a6a09eb614bdf79d069
evidence/C2_before.png	C2 · At testing	2026-11-02 23:19:59	a034a23afacedc86b05b30694bc32bf8475d91a401a1e54a6585d5859772637e
evidence/C3_before.png	C3 · At testing	2026-11-02 23:20:00	6fd71fe0bb65c6d207481dc2f2e0c7bf6e3c8ce0be3cfd4929c5287ecefbd8be
evidence/C4_before.png	C4 · At testing	2026-11-02 23:19:58	7ebe41eaba3a7434bb83f43b13d3e4741e9058718c8a7b93f1e426095a9d8fa0
evidence/C5_before.png	C5 · At testing	2026-11-02 23:19:57	8effb2b8bd897b9960aed8f3100fd82cad625d69bafc9833b3be223a4d8f03c9
evidence/C6_before.png	C6 · At testing	2026-11-02 23:19:57	b80a46132bed28500f1ea7c1d11b793c0b0ae841714b39c6d884f7effd323260
evidence/C7_before.png	C7 · At testing	2026-11-02 23:20:09	774c7fd4c38a1288e7007e209e767e78ae812fd5ce048dcd90536f421a1aab98

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	29	38,374	61,019	0	0.3073
`sam-3.1`	19	0	0	19	price not published
Total					**0.3073**

Personal data in evidence: 18/20 spotted by Muse Spark + SAM, 20/20 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`4ee7b9c9ca4ef5e7d9e08d0a8d0ea268ef17af634a58f686c36acfedba671fbf`